DOCUMENT D08 · ABC BANK

Group IT Security Incident Response Plan

Extract. Cover page states "Version 2.0 — date last amended: May 2024".

Document details	
Title	Group IT Security Incident Response Plan
Version	1.2
Owner	IT Function
Approval date	[DD MMM YYYY]
Effective date	[DD MMM YYYY]

Version	Issue date	Summary of key changes	Prepared / updated by	Reviewed / approved by
1.0		First issue		[Committee / Board]
2.0				[Committee / Board]

1 Introduction

This document sets out ABC Bank's Plan for reporting and dealing with IT security incidents and specifies its obligations under applicable regulatory requirements. This Plan shall be subject to review on a need basis, such as upon changes in operational situations, and at least once a calendar year. This Plan shall be reviewed and approved by the Executive Committee.

3 Roles and responsibilities — Security Incident Response Team (SIRT)

Role	Responsibilities	Responsible party
Incident Response Lead (IRL)	Lead SIRT; keep the Plan documented and up to date; direct internal and external communication	Head of IT
Incident Response Technical Lead (IRTL)	Contain the incident; investigate; report findings to SIRT	VP, Information Security
Incident Response Regulatory Lead (IRRL)	Coordinate regulatory and law-enforcement reporting; authorise onsite investigation	Head of Compliance

4–12 Procedure (summary)

- Detection: end-user reporting, SOC reporting, threat hunting, third-party notification, threat intelligence feeds, device alerts.
- Verification by IRTL; IRL activates the plan for true positives suggesting a breach.
- Triage and scoping: affected assets, BIA rating, impact severity (Minor / Moderate / Critical / Catastrophic) and urgency. IRL alerts the CEO and senior management; initial incident report within 24 hours. A severe incident must be reported to the regulator within the required timeframe.
- Containment, eradication, recovery (per the BCP if activated), remediation (root cause analysis), post-incident report with lessons learned and updates to policy, technology and training.

13 Testing and updates

This Plan will be tested at least annually using walkthroughs and practical simulations of incident scenarios. SIRT will record observations and lessons learned and implement improvements. IRL will ensure the Plan is updated and communicated to SIRT.

Section 14 provides playbooks for malware, unauthorised wireless access points, loss of equipment and non-compliance with the Group Cyber Security Policy.

Sanitised teaching material. Re-typeset extracts of real governance documents; the institution's name, all personal names, addresses, systems, vendors and other identifying details have been changed or removed. Do not attempt to identify the organisation and do not share outside CS5292.